I.E.S. PABLO SERRANO

0369. Implantación de Sistemas Operativos

UD8 - Auditoría de seguridad en sistemas operativos

8.1 Introducción y objetivos de la unidad

8.1.1 Resultado de aprendizaje

Audita la utilización y acceso a recursos, identificando y respetando las necesidades de seguridad del sistema.

Criterios de evaluación:

a) Se han administrado derechos de usuario y directivas de seguridad.

b) Se han identificado los objetos y sucesos auditables.

c) Se ha elaborado un plan de auditorías.

d) Se han identificado las repercusiones de las auditorías en el rendimiento del sistema.

e) Se han auditado sucesos correctos y erróneos.

f) Se han auditado los intentos de acceso y los accesos a recursos del sistema.

g) Se han gestionado los registros de auditoría.

h) Se ha documentado el proceso de auditoría y sus resultados.

📎 Fuente: BOE-A-2009-18355, Anexo I, Módulo Profesional 0369 – Implantación de sistemas operativos.

8.1.2 Estructura de la unidad

Esta unidad se organiza en los siguientes apartados:

8.1 Introducción y objetivos de la unidad
8.2 Seguridad del sistema y derechos de usuario (ra7.a)
8.3 Fundamentos de auditoría del sistema (ra7.b, ra7.e)
8.4 Auditoría de acceso a recursos (ra7.f)
8.5 Registros y gestión de eventos de auditoría (ra7.g)
8.6 Planificación y documentación de auditorías (ra7.c, ra7.d, ra7.h)

8.1.2 Estructura de la unidad (índice detallado)

8.1 Introducción y objetivos de la unidad
8.1.1 Resultado de aprendizaje
8.1.2 Estructura de la unidad
8.1.3 Actividades previstas
8.1.4 Recursos y entorno de trabajo

8.2 Seguridad del sistema y derechos de usuario (ra7.a)
8.2.1 Seguridad en sistemas operativos
8.2.2 Directivas del sistema en Windows
8.2.3 Directivas de seguridad
8.2.4 Derechos de usuario en el sistema operativo

8.3 Fundamentos de auditoría del sistema (ra7.b, ra7.e)
8.3.1 Concepto de auditoría de seguridad
8.3.2 Objetos y sucesos auditables
8.3.3 Sucesos correctos y erróneos

8.1.2 Estructura de la unidad (índice detallado)

8.4 Auditoría de accesos al sistema y a los recursos (ra7.f)

8.4.1 Auditoría de accesos al sistema

8.4.2 Auditoría de acceso a recursos y objetos

8.5 Registros y gestión de eventos de auditoría (ra7.g)

8.5.1 Registros de eventos del sistema

8.5.2 Visor de eventos (Event Viewer)

8.5.3 Interpretación básica de eventos de auditoría

8.6 Planificación y documentación de auditorías (ra7.c, ra7.d, ra7.h)

8.6.1 Planificación de la auditoría en el ciclo de mejora continua

8.6.2 Plan de auditoría del sistema

8.6.3 Impacto de la auditoría en el rendimiento

8.6.4 Documentación de auditorías y resultados

8.1.3 Actividades previstas

Durante el desarrollo de esta unidad se realizarán las siguientes actividades:

- Explicación de los conceptos fundamentales relacionados con la **auditoría de seguridad en sistemas operativos**.
- Análisis de los **objetos y sucesos auditables** en un sistema Windows.
- Configuración de **directivas de auditoría** en el sistema operativo y en directivas de grupo.
- Realización de prácticas de **auditoría de accesos y utilización de recursos** del sistema.
- Análisis e interpretación de **registros de eventos de seguridad** mediante el visor de eventos.
- Diseño básico de un **plan de auditoría de seguridad** para un sistema o dominio.
- Elaboración de **informes de auditoría** a partir de los registros obtenidos durante las prácticas.

8.1.4 Recursos y entorno de trabajo

- **Sistemas operativos de práctica:**
  - **Windows Server 2022 Evaluation** (Controlador de dominio con Active Directory).
  - **Windows 10 / Windows 11** (Equipos cliente unidos al dominio).
- **Entorno de trabajo:**
  - Entorno de **virtualización VDI** proporcionado por el centro.
  - Cada alumno dispondrá de **una máquina servidor y una máquina cliente** dentro de su entorno de prácticas.
- **Material de apoyo:**
  - Guías rápidas y documentación técnica sobre Active Directory.
  - Recursos y enlaces facilitados en el aula virtual.

isard VDI
Windows 11
Windows 10
Windows Server 2022

8.2 Seguridad del sistema y derechos de usuario



En este apartado se analizan los mecanismos que permiten controlar las acciones que los usuarios pueden realizar en un sistema operativo.
Se estudiará cómo se gestionan los derechos de usuario y las directivas de seguridad, y cómo estos elementos permiten definir qué operaciones están permitidas dentro del sistema.
También se introducirá la relación entre la configuración de seguridad del sistema y los procesos de auditoría, que permiten registrar y analizar la actividad de los usuarios.

8.2.1 Seguridad en sistemas operativos

Los sistemas operativos modernos incorporan diversos mecanismos destinados a **proteger el sistema y controlar las acciones que pueden realizar los usuarios**. Estos mecanismos permiten evitar accesos no autorizados, limitar determinadas operaciones y registrar la actividad que se produce en el sistema.

La seguridad del sistema operativo se basa en varios elementos fundamentales:

- **Identificación y autenticación de usuarios**, mediante cuentas de usuario.
- **Control de acceso a recursos**, determinando qué usuarios pueden acceder a archivos, carpetas o servicios.
- **Asignación de privilegios y derechos**, que permiten realizar determinadas operaciones en el sistema.
- **Configuración de directivas**, que establecen reglas de funcionamiento y seguridad.

Estos mecanismos permiten definir **qué acciones están permitidas en el sistema y quién puede realizarlas**, lo que constituye la base sobre la que posteriormente se aplican los **procesos de auditoría de seguridad**.

8.2.2 Directivas del sistema en Windows

En los sistemas Windows muchas configuraciones del sistema se establecen mediante **directivas** (*policies*). Una directiva es una **regla de configuración que determina cómo debe comportarse el sistema operativo o qué acciones pueden realizar los usuarios**.

Las directivas permiten **definir de forma centralizada el funcionamiento del sistema**, evitando configuraciones inconsistentes entre equipos o usuarios.

Mediante las directivas es posible configurar distintos aspectos del sistema operativo, como por ejemplo:

- el comportamiento del sistema,
- el entorno de trabajo de los usuarios,
- la instalación y uso de software,
- la configuración de red,
- o determinados parámetros de seguridad.

Por tanto, las directivas constituyen un **mecanismo fundamental de administración del sistema**, ya que permiten controlar el funcionamiento de los equipos y garantizar que todos cumplen las configuraciones establecidas por la organización.

8.2.3 Directivas de seguridad

Dentro del conjunto de directivas que pueden configurarse en Windows, existe un grupo específico destinado a **definir el comportamiento de seguridad del sistema**. Estas configuraciones se conocen como **directivas de seguridad**.

Las directivas de seguridad permiten establecer **reglas relacionadas con la protección del sistema y el control de las acciones que pueden realizar los usuarios**. Entre otros aspectos, permiten configurar:

- las **políticas de contraseñas**,
- las **políticas de bloqueo de cuentas**,
- la **asignación de derechos de usuario**,
- las **opciones de seguridad del sistema**,
- y la **configuración de auditoría**.



Estas directivas forman parte de la **configuración de seguridad del sistema operativo** y permiten definir las condiciones bajo las cuales los usuarios pueden acceder al sistema, utilizar determinados privilegios o realizar ciertas operaciones.

Ejercicio en clase: ¿Es directiva de seguridad o no?

1. Establecer una longitud mínima de contraseña de 10 caracteres para todas las cuentas del dominio.

2. Impedir que los usuarios puedan acceder al Panel de control del sistema.

3. Registrar en el sistema los intentos fallidos de inicio de sesión.

4. Impedir que los usuarios puedan ejecutar el símbolo del sistema (cmd.exe).

5. Permitir que solo determinados grupos puedan iniciar sesión localmente en un equipo.

8.2.4 Derechos de usuario en el sistema operativo

Además de los permisos de acceso a recursos, los sistemas operativos permiten definir **qué acciones puede realizar un usuario dentro del propio sistema**. Estas capacidades se establecen mediante los **derechos de usuario** (*user rights*).

Los derechos de usuario determinan **qué operaciones del sistema puede realizar un usuario o un grupo**, independientemente de los permisos que tenga sobre archivos u otros recursos.

Entre los derechos de usuario más habituales se encuentran, por ejemplo:

- **Iniciar sesión localmente en el sistema.**
- **Iniciar sesión a través de la red.**
- **Apagar o reiniciar el sistema.**
- **Realizar copias de seguridad.**
- **Restaurar archivos y directorios.**

En la práctica, estos derechos **no suelen asignarse a usuarios individuales**, sino a **grupos**, lo que facilita la administración del sistema y permite aplicar configuraciones coherentes para distintos tipos de usuarios.

Ejercicio en clase: Derechos de usuario secpol.msc

1. En un equipo de laboratorio queremos permitir que los alumnos puedan conectarse a las carpetas compartidas desde otros equipos de la red, pero sin iniciar sesión físicamente en el ordenador. ¿Qué derecho de usuario controla este acceso?

2. En un servidor del aula solo los administradores deberían poder apagar o reiniciar el sistema. ¿Qué derecho de usuario deberíamos revisar?

3. Un técnico necesita iniciar sesión directamente en un equipo para realizar tareas de mantenimiento en el laboratorio. ¿Qué derecho de usuario permite este tipo de acceso?

Ejercicio en clase: Derechos de usuario secpol.msc

4. El departamento de sistemas quiere asignar a un grupo la capacidad de realizar copias de seguridad del sistema, incluso de archivos para los que no tienen permisos NTFS. ¿Qué derecho de usuario lo permite?

5. Durante una recuperación del sistema es necesario restaurar archivos desde una copia de seguridad, aunque el usuario que lo haga no sea el propietario de los archivos originales. ¿Qué derecho de usuario permite esta operación?

8.3 Fundamentos de auditoría del sistema



La auditoría de seguridad permite registrar y analizar la actividad que se produce en un sistema operativo. A través de estos mecanismos es posible conocer qué acciones realizan los usuarios, detectar accesos indebidos y verificar el cumplimiento de las políticas de seguridad establecidas.

8.3 Fundamentos de auditoría del sistema



La auditoría de seguridad permite registrar y analizar la actividad que se produce en un sistema operativo. A través de estos mecanismos es posible conocer qué acciones realizan los usuarios, detectar accesos indebidos y verificar el cumplimiento de las políticas de seguridad establecidas.

8.3.1 Concepto de auditoría de seguridad

La auditoría de seguridad es el conjunto de mecanismos que permiten **registrar y analizar las acciones realizadas en un sistema operativo** con el objetivo de evaluar su seguridad.

¿Qué es?

Se basa en la definición de **qué actividades deben ser auditadas**, permitiendo conocer:

- quién realiza una acción
- sobre qué recurso
- y en qué contexto

La auditoría proporciona **trazabilidad de la actividad del sistema**, lo que permite:

- detectar comportamientos anómalos
- investigar incidentes de seguridad
- verificar el cumplimiento de las políticas establecidas

¿Para qué sirve?

8.3.2 Objetos y sucesos auditables

Un sistema operativo no permite auditar cualquier acción, sino únicamente aquellas que están definidas como **auditables** mediante sus mecanismos de seguridad.

En Windows, la auditoría se organiza en **categorías de eventos**, que agrupan los distintos tipos de actividad que pueden registrarse. Entre las principales se encuentran:

¿Qué puedo auditar?

- **Inicio de sesión:** autenticación de usuarios en el sistema
- **Administración de cuentas:** creación, modificación o eliminación de usuarios y grupos
- **Acceso a objetos:** uso de archivos, carpetas, impresoras u otros recursos
- **Uso de privilegios:** ejercicio de derechos de usuario
- **Cambio de directivas:** modificaciones en la configuración de seguridad
- **Eventos del sistema:** acciones que afectan al funcionamiento del sistema

Estas categorías definen **qué tipo de actividad puede ser auditada**, y constituyen la base para la configuración posterior de la auditoría.

Ejercicio en clase: ¿Es un suceso auditable?

1. Un usuario inicia sesión en el sistema
2. Un usuario abre el navegador web
3. Se intenta acceder a una carpeta sin permisos
4. Un administrador crea una nueva cuenta de usuario
5. Un usuario cambia el fondo de pantalla
6. Se modifica una directiva de seguridad
7. Un usuario apaga el equipo
8. Un usuario navega por el menú de configuración

8.3.3 Sucesos correctos y erróneos

En la auditoría de seguridad, los eventos pueden clasificarse según el resultado de la acción realizada:

- **Sucesos correctos (éxitos):**
  Acciones que se completan correctamente dentro del sistema
  (ej. inicio de sesión válido, acceso autorizado a un recurso)
- **Sucesos erróneos (errores):**
  Intentos de realizar una acción que no se permite
  (ej. contraseña incorrecta, acceso denegado a un archivo)

La configuración de auditoría permite decidir si se registran: solo los éxitos, solo los errores o ambos tipos de eventos

La elección depende del objetivo de la auditoría:

- **Errores → detección de intentos no autorizados**
- **Éxitos → trazabilidad completa de la actividad**

8.3.3 Sucesos correctos y erróneos (ejemplo)

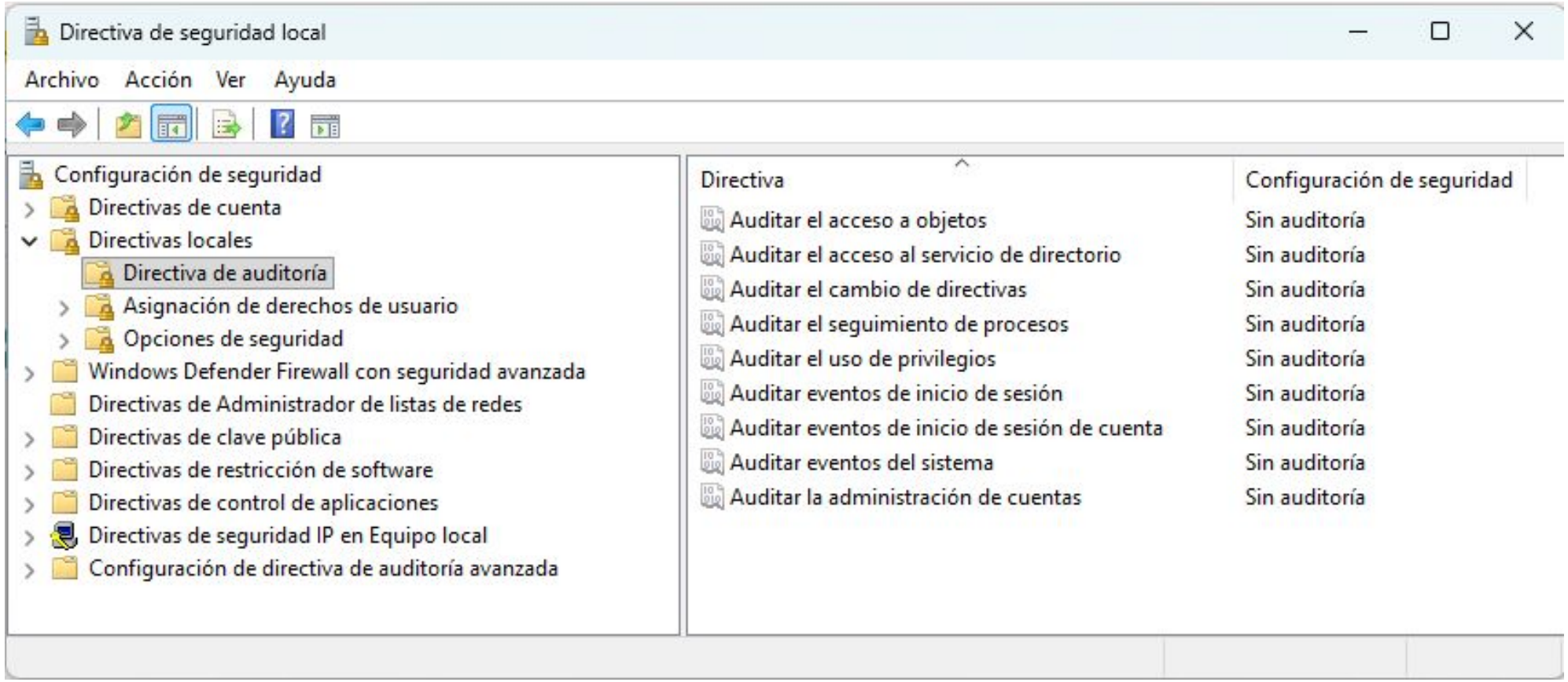
Escenario: Auditoría de inicios de sesión en un servidor

- **Auditar errores (fallos):**
  Se registran intentos de login con contraseña incorrecta
  👉 Permite detectar posibles ataques o accesos no autorizados

- **Auditar éxitos:**
  Se registran los inicios de sesión válidos
  👉 Permite conocer qué usuario ha accedido y en qué momento

Auditar errores ayuda a detectar problemas; auditar éxitos permite reconstruir la actividad.

8.4 Auditoría de accesos al sistema y a los recursos



La auditoría de acceso a recursos permite registrar y analizar cómo los usuarios interactúan con los elementos del sistema, como archivos, carpetas o servicios. Estos mecanismos hacen posible detectar accesos no autorizados, verificar el uso adecuado de los recursos y garantizar el cumplimiento de las políticas de seguridad.

8.4.1 Auditoría de accesos al sistema

La auditoría de accesos al sistema permite registrar los eventos relacionados con la **autenticación de usuarios** en un equipo o en un dominio.

En Windows, estos eventos se agrupan en dos categorías:

- **Eventos de inicio de sesión (Logon events):**
  Se registran en el equipo donde se produce el acceso
- **Eventos de inicio de sesión de cuenta (Account logon events):**
  Se registran en el controlador de dominio cuando se valida la autenticación

Estos eventos permiten registrar:

- Inicios y cierres de sesión
- Intentos fallidos de autenticación
- Tipo de acceso (local, remoto, red)

Permiten detectar accesos no autorizados y analizar la actividad de acceso al sistema.

8.4.2 Auditoría de acceso a recursos y objetos

La auditoría de acceso a recursos permite registrar los intentos de acceso a **objetos del sistema**, como archivos, carpetas, impresoras o claves del registro.

En Windows, esta auditoría se basa en la categoría: **Acceso a objetos (Object Access)**

A diferencia de la auditoría de inicio de sesión, en este caso es necesario:

- Definir qué tipo de acceso se audita (lectura, escritura, eliminación, etc.)
- Configurar la auditoría sobre el propio objeto mediante su **lista de control de auditoría (SACL)**

Esto permite registrar:

- Accesos correctos a recursos
- Intentos de acceso denegados
- Tipo de operación realizada sobre el objeto

La auditoría de acceso a objetos permite:

- Detectar accesos indebidos a información
- Controlar el uso de recursos sensibles
- Analizar quién accede a qué recurso y cómo lo hace

ACL, DACL y SACL en Windows (NTFS)

En Windows, la seguridad de los objetos (archivos, carpetas, etc.) se basa en una **ACL (Access Control List)**, almacenada como parte de sus **metadatos**.

La ACL forma parte del **descriptor de seguridad del objeto** y se compone de:

- **DACL (Discretionary ACL)**
  → Define los permisos de acceso (modelo NTFS)
  → Qué usuarios o grupos pueden leer, escribir, modificar, etc.

- **SACL (System ACL)**
  → Define la auditoría
  → Qué accesos o intentos de acceso deben registrarse

Cada objeto tiene su **ACL ya construida**, que incluye:

- permisos explícitos
- permisos heredados

Estos permisos se almacenan como **configuración efectiva del objeto**, que Windows utiliza para evaluar accesos y generar eventos de auditoría.

Ejercicio en clase: detección de intentos de acceso

Un administrador sospecha que se están produciendo **intentos repetidos de acceso no autorizado** en un equipo.

Pregunta:

¿Qué deberías auditar para poder detectar este tipo de comportamiento?

Tarea:

- Investiga qué opciones de auditoría debes configurar en el sistema
- Activa la auditoría correspondiente (pista: *directivas de seguridad local*)
- Realiza varios intentos fallidos de inicio de sesión
- Comprueba si el sistema registra estos intentos

Pistas:

secpol.msc
eventvwr.msc

Ejercicio en clase: auditoría de acceso a recursos

Un administrador necesita controlar **quién accede a una carpeta sensible** y detectar intentos de acceso no autorizados.

Pregunta:
¿Qué deberías configurar para poder registrar estos accesos?

Tarea:

- Crea una carpeta en tu equipo (por ejemplo: *Datos_Prueba*)
- Investiga cómo configurar la auditoría sobre ese recurso
- Activa el registro de accesos (pista: propiedades del objeto)
- Intenta acceder a la carpeta con y sin permisos
- Comprueba si el sistema registra los accesos

Pistas:

Propiedades → Seguridad → Opciones avanzadas → Auditoría
eventvwr.msc

8.5 Registros y gestión de eventos de auditoría (ra7.g)



La auditoría del sistema solo tiene sentido si los eventos generados pueden ser **registrados, consultados e interpretados correctamente**. En este apartado se aborda el uso de los **registros de eventos en Windows**, centrándonos en cómo acceder a ellos, qué información contienen y cómo utilizarlos para analizar la actividad del sistema y detectar posibles incidencias de seguridad.

8.5.1 Registros de eventos del sistema

Windows dispone de un sistema de registros que almacena los eventos generados por el sistema operativo y las aplicaciones, incluyendo aquellos derivados de la auditoría de seguridad.

Estos eventos se organizan en distintos registros, entre los que destacan:

- **Seguridad**
  → Eventos de auditoría (inicio de sesión, acceso a recursos, cambios de configuración)
- **Sistema**
  → Eventos del sistema operativo (servicios, drivers, errores)
- **Aplicación**
  → Eventos generados por aplicaciones

El registro de **Seguridad** es el principal en el contexto de auditoría, ya que contiene la información necesaria para analizar accesos, intentos fallidos y actividad relevante del sistema.

Estos registros permiten al administrador consultar y analizar la actividad del sistema, constituyendo la base para la detección de incidencias y el análisis forense.

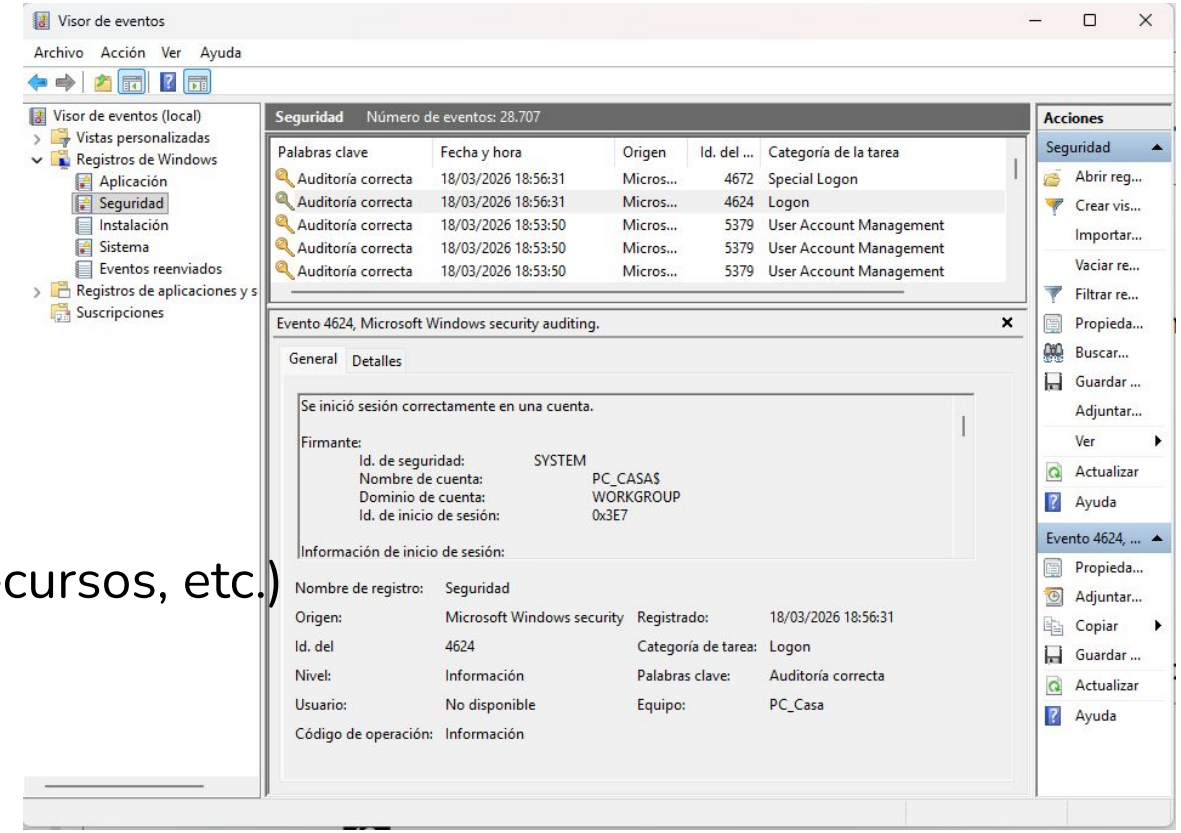
8.5.2 Visor de eventos (Event Viewer) (I)

El **Visor de eventos** es la herramienta de Windows que permite consultar los registros generados por el sistema y la auditoría.

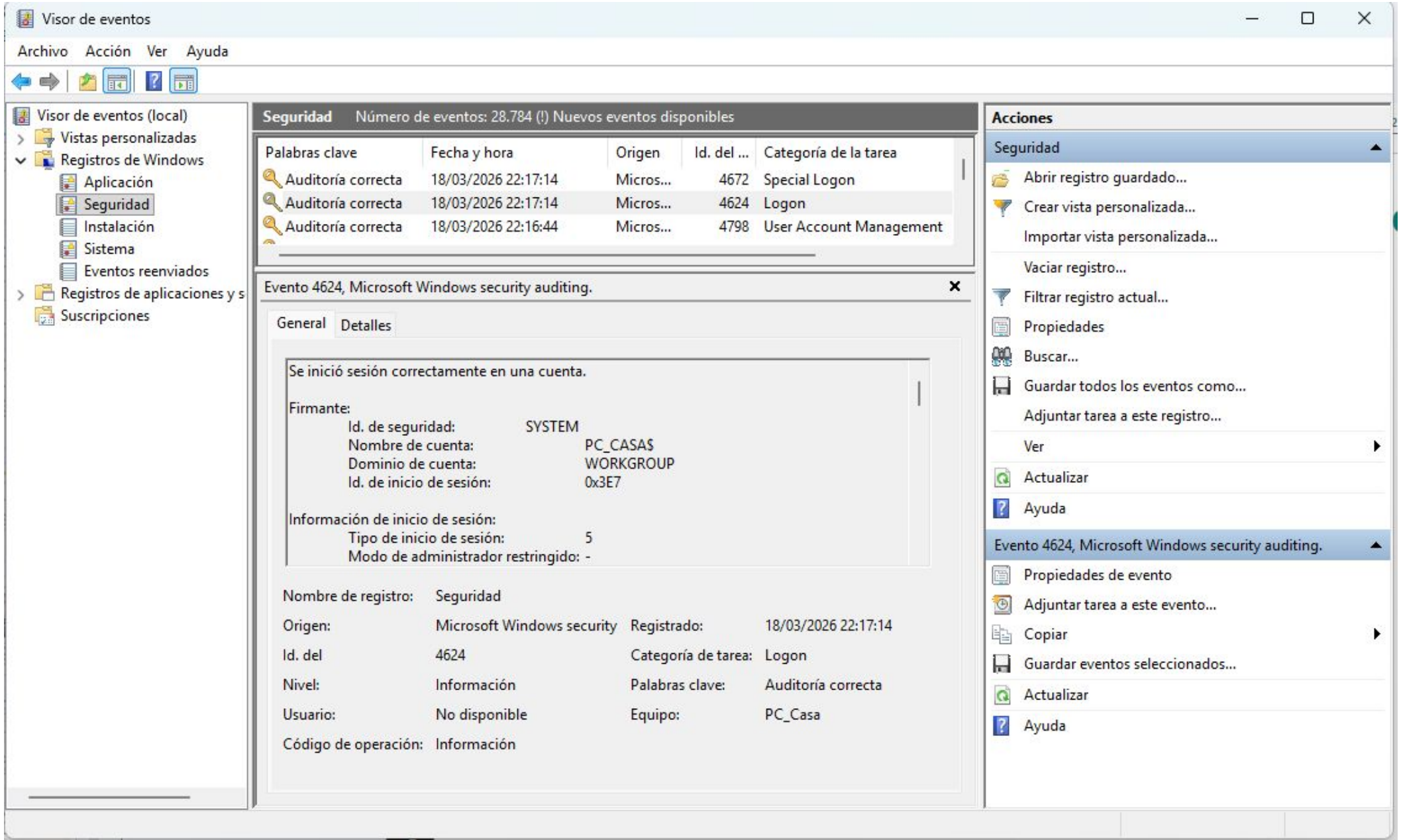
En el registro de **Seguridad**, cada evento muestra información sobre una acción realizada en el sistema.

Los campos más relevantes son:

- **Id. del evento (Event ID)**
  → identifica el tipo de suceso
- **Fecha y hora**
  → momento en el que ocurre
- **Categoría de tarea**
  → tipo de acción (inicio de sesión, acceso a recursos, etc.)
- **Nivel**
  → información, advertencia o error
- **Palabras clave**
  → indica si la acción ha sido correcta o fallida



8.5.2 Visor de eventos (Event Viewer) (II)



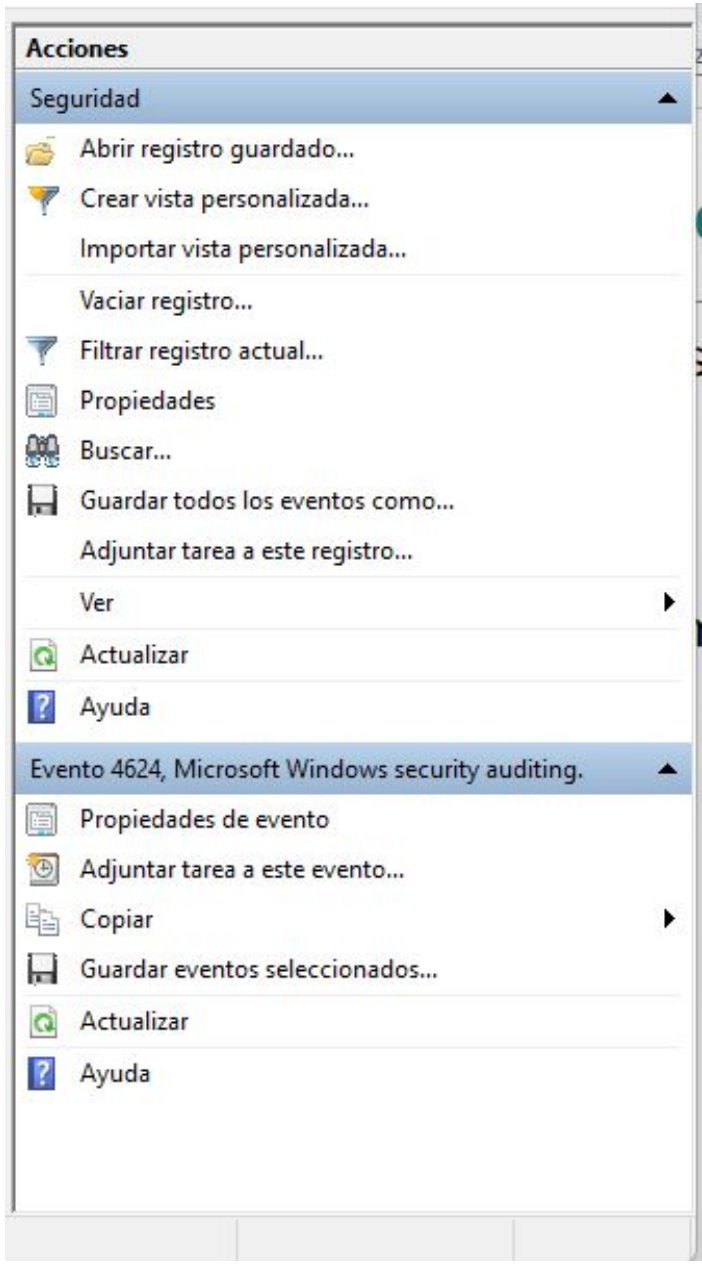
8.5.2 Visor de eventos (Event Viewer) (VI)

Análisis y gestión de eventos

El Visor de eventos permite trabajar con grandes volúmenes de información mediante distintas herramientas de análisis:

- **Filtrado de eventos**
  → permite acotar por tipo, ID, usuario o intervalo de tiempo
- **Búsqueda de eventos concretos**
- **Vistas personalizadas**
  → agrupación de eventos según criterios definidos
- **Asociación de tareas a eventos**
  → ejecución automática de acciones ante determinados eventos

Estas funcionalidades permiten al administrador identificar rápidamente eventos relevantes dentro de un gran volumen de registros.



8.5.2 Visor de eventos (Event Viewer) (VI)

Eventos de seguridad por defecto en Windows

Windows registra por defecto determinados eventos de seguridad, incluso sin configuración manual de auditoría.

Esto se debe a que el sistema incluye una configuración base de auditoría, que permite registrar actividad relevante como:

- Inicios de sesión
- Gestión de cuentas
- Cambios en grupos de seguridad

La configuración de auditoría realizada por el administrador permite ampliar y ajustar este comportamiento, definiendo qué eventos deben registrarse y con qué nivel de detalle.

8.6 Planificación y documentación de auditorías



La auditoría del sistema no es una acción puntual, sino un proceso continuo orientado a mejorar la seguridad. En este apartado se aborda cómo planificar, analizar y documentar las auditorías, considerando también su impacto en el rendimiento. El objetivo es integrarlas en un ciclo de mejora continua que permita detectar problemas, aplicar medidas correctoras y verificar su eficacia.

8.6.1 La auditoría en el ciclo de mejora continua

La seguridad del sistema se gestiona como un proceso continuo basado en el ciclo PDCA (Plan-Do-Check-Act). En este ciclo, se diseñan e implementan las medidas de seguridad, se verifican mediante auditoría y se ajustan para mejorar el sistema.



8.6.2 Plan de auditoría del sistema

El plan de auditoría establece cómo se va a verificar la seguridad del sistema dentro del ciclo de mejora continua. Aunque la auditoría pertenece a la fase de comprobación (**CHECK**), es necesario establecer previamente su alcance, objetivos y condiciones de ejecución.

Un plan de auditoría debe contemplar:

- Alcance del sistema a auditar (equipos, servicios, dominio)
- Objetivos de la auditoría (seguridad, cumplimiento, trazabilidad)
- Frecuencia y momento de ejecución*
- Responsables y roles implicados
- Procedimiento de revisión, análisis y toma de decisiones

8.6.3 Impacto de la auditoría en el rendimiento

La auditoría del sistema implica la **generación y almacenamiento continuo** de eventos. Esto puede afectar al rendimiento si no se configura adecuadamente. Es necesario equilibrar el nivel de auditoría con la capacidad del sistema.

Entre los principales impactos se encuentran:

- Incremento del uso de CPU y memoria
- Aumento del tamaño de los registros de eventos (logs)
- Mayor consumo de almacenamiento
- Posible degradación del rendimiento en sistemas críticos

Para minimizar este impacto:

- Auditar únicamente eventos relevantes
- Ajustar el nivel de detalle de la auditoría
- Establecer políticas de retención y rotación de logs
- Revisar periódicamente la configuración de auditoría

8.6.4 Documentación de auditorías y resultados

La documentación de la auditoría permite registrar, analizar y comunicar el estado de seguridad del sistema. Debe seguir una estructura clara que facilite la interpretación de los resultados y la toma de decisiones. Un informe de auditoría debe incluir:

Nº	Apartado	Qué debe incluir
1	Identificación de la auditoría	Nombre del dominio o equipo, fecha y autor del informe
2	Objetivo y alcance	Qué se quiere comprobar y sobre qué elementos (usuarios, equipos, accesos, etc.)
3	Evidencias obtenidas	Capturas o eventos relevantes del visor de eventos (logs)
4	Incidencias detectadas	Problemas encontrados (accesos indebidos, errores, intentos fallidos, etc.)
5	Medidas correctoras	Qué se debería cambiar o mejorar en la configuración
6	Conclusión final	Valoración general del estado del sistema (correcto, mejorable, inseguro, etc.)

UD8.PrA – Auditoría de seguridad en Active Directory

En esta práctica se llevará a cabo una **auditoría de seguridad** sobre un dominio **Active Directory** previamente configurado. El alumnado deberá planificar la auditoría, configurar las directivas necesarias, generar y analizar eventos relacionados con **inicios de sesión** y **acceso a recursos**, y elaborar un informe basado en evidencias. Además, se identificará una situación mejorable en el sistema, se aplicarán **medidas correctoras** y se verificará su eficacia mediante una nueva auditoría, completando así el **ciclo de mejora continua**.

La auditoría no evita incidentes, pero permite detectarlos y analizarlos. La seguridad real combina prevención y auditoría.